Departamento de Lenguajes y Sistemas Informáticos
E.T.S. Ingeniería Informática. Universidad de Sevilla

Avda Reina Mercedes s/n. 41012 Sevilla
E-mail lsi@lsi.us.es **Web** www.lsi.us.es

E.T.S. ingeniería informática

SEGURIDAD EN SISTEMAS INFORMÁTICOS Y EN INTERNET

CAI 1. CONSULTA DE ASEGURAMIENTO DE LA INFORMACIÓN

Parte 2. ROBUSTEZ DE LA INTEGRIDAD DE LA INFORMACIÓN EN LAS TRANSMISIONES

La entidad bancaria permite a sus clientes realizar transferencias financieras a través de la aplicación para móviles que pueden descargar. Para mantener la integridad de las transferencias, la transmisión se hace de **"forma segura"** usando **Códigos de Autenticación de Mensajes (HMAC)** para los mensajes realizados por el cliente al servidor con **claves secretas de tamaño 32 bits.** Dicha entidad entrega a los clientes cada año un dispositivo físico (pendrive, smartcard, SD memory, …) que contiene dicha clave para realizar todas las gestiones financieras que deseen durante el año.

La **Política de Seguridad propuesta** de la entidad especifica **que todas las transmisiones de información de la entidad con los clientes deben ser íntegras (en esta consultoría no se tendrá en cuenta la confidencialidad),** evitando **los posibles ataques** (man-in-the-middle, replay, etc.)**.** No obstante, la entidad tiene dudas razonables sobre **la robustez del algoritmo de generación HMAC y si el tamaño de las claves usadas para HMAC es adecuada actualmente**.

La entidad financiera nos envía para que respondamos a la consulta de un conjunto de mensajes, donde el primer número corresponde a la cuenta origen, el segundo número es la cuenta destino y el tercero la cantidad que se desea transferir (**hay que tener en cuenta que entre los números solamente hay un espacio en blanco**). Los mensajes recibidos en INSEGUS son los siguientes:

Mensaje	HMAC
`34567893 987344 120`	`CLxpGZUJ6GkQzdNHOZsVJC1PVlUWDSg6e6oIu2Yv5Zk=`
`34567894 986454 10`	`we7bS6LiKkOdZ408IXyReGUSexNm0F7kJXOeQGeCfyI=`
`34537895 957769 110`	`bT42fKu1YvprxMGun/SUIarQC/Ie/emtRXQYxIrRg3I=`

Las consultas que nos hace el cliente son las siguientes:

a. **Informar al cliente si es seguro el tamaño de clave que está usando para preservar la integridad de las transmisiones justificando la razón de ello**. El cliente nos sugiere que se le informe del **tiempo que se tarda en encontrar la clave**. **Razone si es un tiempo lo suficientemente alto como para garantizar la seguridad de la clave.**
   Muestre el proceso a seguir y las claves obtenidas en un anexo del documento para que pueda ser revisado.
b. En caso de que el Security Team considere que no sea seguro el tamaño de clave usado, realizar una recomendación acerca del tamaño de clave que se considera adecuado (el cliente nos solicita que se haga explícito el razonamiento seguido para llegar a recomendar

dicho tamaño) desde un punto de vista de la capacidad computacional que tuvieran los posibles atacantes, suponiendo que estos tuviesen una potencia de cálculo 1000 veces superior a la computadora con que se ha realizado la experimentación. Además, el cliente nos solicita que le indiquemos si consideramos que puede mejorarse el proceso de entrega de claves a los clientes de la entidad financiera.

Normas del entregable

- Cada ***Security Team X*** debe entregar el informe ST-X-CAI1B.pdf que contenga todos los detalles que responden a los puntos de la consultoría (se debe indicar expresamente los alumnos del equipo que han participado en el trabajo) a través de la actividad creada al efecto en el curso de Enseñanza Virtual. El informe debe recoger evidencias del proceso, herramientas y pruebas realizadas, así como de las respuestas a las consultas planteadas.
- La consulta se desarrollará en la sesión dispuesta al efecto, y en el tiempo indicado por el profesor.